

CCSP 閃卡全部

CCSP flashcards for Knowt. 232 cards. Upload this PDF to AI PDF Summarizer.

Q001 Public cloud 的定義是什麼？

A 開放給一般公眾使用，通常由雲端服務提供者擁有、管理及營運。不要和 private cloud 搞混。

Q002 Private cloud 的定義是什麼？

A 僅供單一組織專屬使用。

Q003 Hybrid cloud 的定義是什麼？

A 由兩個以上不同雲端基礎架構組成，並以標準化技術連結。

Q004 Community cloud 的定義是什麼？

A 供具有共同關注事項的特定消費者群體專屬使用。

Q005 Multicloud 一定等於 Hybrid cloud 嗎？

A 不一定。Multicloud 是使用多家 CSP；Hybrid 強調不同基礎設施被標準化技術綁在一起。

Q006 IaaS 最主要的商業驅動力是什麼？

A Transfer of ownership cost：CapEx 轉 OpEx。不要先選能源或冷卻效率。

Q007 IaaS / PaaS / SaaS 客戶各管什麼？

A IaaS：客戶管 OS / app / data；PaaS：客戶專注 app / code；SaaS：CSP 提供完整應用。

Q008 Cloud Broker 做什麼？

A 仲介、彙整、整合或管理雲端服務。

Q009 Cloud Reseller 做什麼？

A 購買 hosting / cloud service 後轉售給自己的客戶。不要選 Broker。

Q010 Cloud Carrier 做什麼？

A 提供連線與傳輸 (connectivity and transport)。

Q011 Cloud Auditor 做什麼？

A 執行獨立評估 (independent assessment)。

Q012 Interoperability 與 Portability 差在哪？

A Interoperability 是系統能否一起運作與交換；Portability 是工作負載 / 資料能否搬走。

Q013 ISC2 語境中，推動企業投入資安的最大外部因素通常是什麼？

A Regulation (法規)，不是「不斷演進的威脅」。

Q014 Access control criteria 最終應主要源自什麼？

A Organizational policy / business requirements。外部法規要先轉成組織政策，再變成 IAM / ACL。

Q015 GLBA 是什麼？

A Gramm–Leach–Bliley Act：美國聯邦法律，保護金融機構客戶的非公開個人資訊。

Q016 PCI DSS 是法律嗎？

A 不是。PCI DSS 是支付卡產業安全標準，不是聯邦隱私法。

Q017 Privacy 需求如何影響 deployment model？

A 高隱私 / 專屬控制需求通常偏向 private 或 community；open public 不適合高度敏感專屬資料。

Q018 FaaS / Serverless 的考試重點是什麼？

A Event-driven function；客戶不管 server 管理，但仍要管程式、權限與資料。

Q019 為什麼 cloud sprawl 不只是基礎設施帳單問題？

A 還可能增加 OS、資料庫、資安設備與企業軟體的授權、訂閱與管理成本。

Q020 Asset inventory 回答什麼？BIA 回答什麼？

A Inventory 回答「我們有什麼」；BIA 回答「什麼最重要、中斷會怎樣」。

Q021 Business requirements 能補技術盤點缺的什麼？

A Business usefulness / value / criticality，這些不一定能只靠客觀 technical inventory 得到。

Q022 Production 在 CSP-A、backup 在 CSP-B，recovery 最直接的技術風險是什麼？

A Interoperability / proprietary format incompatibility。這比泛稱 vendor lock-in 更直接卡住還原目標。

Q023 ISC2 兩個答案都合理時怎麼選？

A 選最直接解決題目所問 business / security objective 的答案，不要總選範圍最大的風險名詞。

Q024 組織把工作放到雲端後，誰仍通常保有 accountability？

A Organization / data owner / controller。Responsibility 可委外，accountability 通常不消失。

Q025 評估 CSP 時，除了 CSP 本身安全態勢還要看什麼？

A 它所依賴的 third parties / subprocessors / supply chain。CSP secure ≠ 整條服務鏈 secure。

Q026 Cloud Secure Data Lifecycle 六個階段依序是什麼？

A Create → Store → Use → Share → Archive → Destroy。口訣 C-S-U-S-A-D。

Q027 資料一建立時，最早應執行哪項治理活動？

A Classification。後續 encryption、IAM、DLP、retention、sharing、destruction 都可能依賴它。

Q028 Share 之前是哪一個 lifecycle phase？

A Use。Encrypt / Protect / Validate 是 control，不是 phase。

Q029 Control 和 lifecycle phase 差在哪？

A Phase 是資料所處階段；control 是保護手段。看到 encrypt / tokenize / DLP 先問是不是被拿來冒充 phase。

Q030 Metadata 是什麼？

A Data about data：建立時間、作者、檔案類型、位置、擁有者、schema 等描述資訊。

Q031 Label / Tag 是什麼？

A 刻意附加的分類或治理標誌，例如 Confidential、PII、Restricted。

Q032 Classification 問的是什麼問題？

A 這份資料有多敏感 / 屬哪一類？它是決策，不是自動產生的描述欄位。

Q033 Data Discovery 的核心功能是什麼？

A 找出敏感資料在哪裡、內容是什麼，並做內容檢視與盤點。

Q034 DLP 的核心功能是什麼？

A 依內容辨識敏感資料，監控或阻止不當流動。記：DLP = movement。

Q035 IRM / DRM 與 DLP 最大差異是什麼？

A IRM 控制授權後能做什麼 (view / copy / print / forward)；DLP 關心資料正在去哪裡。

Q036 DRM 與 Enterprise DRM / IRM 的關係？

A DRM 是防止未授權複製的廣義機制；Enterprise DRM / IRM 是其企業文件權限子集。

Q037 DLP 一定要裝在 client 上嗎？

A 不一定。可位於 endpoint、network 或 cloud / SaaS / CASB。不要背「egress monitoring 一定有 client agent」。

Q038 Content-based discovery 較接近哪類控制？

A Egress monitoring / DLP 類方案，不是 DRM。DRM 管使用權，不管內容發現。

Q039 DLP 能不能當合約仲裁或 HR 評估工具？

A 不能。DLP 是 data-centric control：識別、分類比對、監控、告警 / 阻擋。

Q040 VM 看到邏輯磁碟但實體不一定靠近 compute node，通常是哪種儲存？

A Volume / Block storage。不要選 CDN。

Q041 Object storage 的特徵是什麼？

A Object + metadata + identifier，通常經 API 存取。

Q042 CDN 的核心目的是什麼？

A 把內容快取 / 派發到靠近使用者處，追求 delivery / performance，不是通用附加儲存區。

Q043 IaaS / PaaS / SaaS 典型儲存對應？

A IaaS → Volume / Object；PaaS → Databases；SaaS 常搭配 CDN 派發靜態內容。

Q044 為什麼 traditional overwrite 在 cloud 可能不可靠？

A 客戶通常無法控制實體媒體，且資料可能在 snapshot、replica、backup 中。不是因為「主管機關不喜歡覆寫」。

Q045 Physical destruction 和 crypto-erasure 哪個一定比較安全？

A 不能脫離情境。先問誰控制實體媒體。

Q046 雲端最普遍可行的資料銷毀方法通常是什麼？

A Encryption / crypto-erasure（銷毀金鑰使資料不可讀）。Degaussing、物理銷毀、覆寫對客戶常不可行。

Q047 Degaussing 為什麼很少是雲端客戶的答案？

A 客戶通常無法保證對 CSP 磁性媒體執行消磁。

Q048 PCI DSS 交易授權後通常不能保留的 SAD 是什麼？

A CVV / CVC。PAN 可在符合保護要求下儲存；PCI DSS 本身是產業標準不是法律。

Q049 TDE 的加密引擎在哪一層？

A Database / DBMS 層。不要把 KMS 當成 encryption engine。

Q050 KMS 做什麼？

A 管理金鑰生命週期、輪換與存取控制；管 key，不一定執行資料加密。

Q051 HSM 是什麼？

A 防篡改硬體，用於金鑰儲存與密碼運算。它是安全容器，不是金鑰本身。

Q052 BYOK 與 HYOK 差在哪？

A BYOK：客戶自帶 key 給 CSP 使用；HYOK：客戶自己持有 key，CSP 不持有。

Q053 Envelope encryption 是什麼？

A Data key 加密資料，master key 再加密 data key。

Q054 Tokenization 是什麼？

A 用 token 替代真值，原值存在 token vault。

Q055 Dynamic masking 與 static masking 差在哪？

A Dynamic：查詢 / 顯示時依角色遮罩、不改原資料；Static：產生已遮罩副本。

Q056 Format-Preserving Encryption 的特點？

A 加密後仍保持原資料格式，例如看起來仍像信用卡號。

Q057 分類是否永久不變？

A 不是。時間、用途改變、所有權移轉、法規狀態都可能觸發 reclassification。

Q058 哪一項通常不是 reclassification 的理由？

A Color change。顏色改變通常與敏感度分類無關。

Q059 Data Controller 與 Processor 差在哪？

A Controller 決定 why + how；Processor 依指示處理。CSP 常可能是 processor / subprocessor。

Q060 PII 放在 CSP，CSP 發生 breach，customer 的 accountability 消失嗎？

A 不會。責任可共享或委外，歸責通常仍在 data owner / controller。

Q061 CSA CCM 是什麼？

A 雲端控制框架 (control objectives / domains)，可 mapping 其他標準。不要背完整 mapping 清單。

Q062 CAIQ 是什麼？

A CSA 的評估問卷，用來詢問 CCM 控制如何實作。

Q063 STAR 是什麼？

A CSA 的雲端供應商保證 / 登錄計畫，不是成熟度模型。

Q064 SSAE 18 與 SOC 1 / SOC 2 差在哪？

A SSAE 18 是認證 / attestation 標準；SOC 1 / 2 是報告類型。

Q065 SOC 1 與 SOC 2 各看什麼？

A SOC 1：財務報導控制；SOC 2：security / privacy 等信任原則控制。

Q066 Anonymization 的考試重點？

A 降低或移除身份關聯，使資料無法合理識別個人；不要和 masking / tokenization 混成同一個答案。

Q067 Egress monitoring 與 stateful inspection 差在哪？

A Stateful inspection 是防火牆 / 網路狀態追蹤；egress monitoring / DLP 是看敏感資料是否外流。

Q068 Create 階段之後，Store 通常要做什麼？

A 依 classification 選擇適當儲存與加密。

Q069 Archive 階段的核心是什麼？

A Retention 與長期保護，不是立即 destroy。

Q070 雲端資料刪除還要考慮哪些複本？

A Replicas、snapshots、backups。銷毀「邏輯物件」不等於所有複本都消失。

Q071 Key rotation 的目的？

A 定期更換金鑰，降低長期暴露與金鑰洩漏衝擊。

Q072 Key escrow 是什麼？

A 以受控方式把金鑰託管給第三方或指定保管者，以便緊急復原，但會引入託管風險。

Q073 資料分類為何要盡早？

A 愈早分類，後續儲存位置、加密強度、DLP 政策、分享限制與銷毀方法才有依據。

Q074 IRM 即使檔案已被合法取得，仍可限制什麼？

A View、copy、print、forward、expiration 等使用權限。

Q075 Discovery 能做 classification 嗎？

A Discovery 可依內容協助識別與分類，但 classification 仍是敏感度決策；兩者不要劃等號。

Q076 D2 最常見的混用錯誤是什麼？

A 把 Metadata、Label、Classification、Discovery、DLP、IRM 當成同一個「資料保護」答案。

Q077 題目出現「自動附加到資料、描述資料本身」最接近什麼？

A Metadata，不是 label。Label 是刻意打上的分類標記。

Q078 雲端無法保證物理銷毀時，可行替代是什麼？

A 在金鑰架構正確的前提下做 cryptographic erasure / crypto-shredding。

Q079 FIPS 140-2 與 FIPS 140-3 怎麼記？

A FIPS 140-2 是 legacy；FIPS 140-3 是現行世代。理解歷史即可，不要用舊版建立新模型。

Q080 資料安全題先問哪五件事？

A 誰擁有資料、誰定政策、誰接受風險、誰操作控制、誰仍須負責 (accountable)。

Q081 高架地板 (raised flooring) 的設計目的是什麼？

A 作為空調通風管道 (air plenum) 與佈線通道。不是避難所或儲藏室。

Q082 高架地板下方線材不整理，最大危害通常是什麼？

A 阻礙氣流、降低 HVAC 效率。不要先選防跌倒。

Q083 MAD 是什麼？

A Maximum Allowable Downtime (亦見 MTD)：業務決定的最大可容忍停機時間。

Q084 RTO 與 MAD 的關係？

A RTO 必須小於 MAD。IT 復原目標不能超過業務上限。

Q085 RPO 衡量什麼？

A 可容忍的資料損失量（以時間表示的 recovery point）。

Q086 誰負責攔截與協調硬體資源呼叫？

A Hypervisor，不是一般系統管理員。

Q087 DR 計畫應該寫給誰執行？

A 任何具備基本技能的人。核心團隊災難時可能無法連線。

Q088 MFA 是最根本的安全原則嗎？

A 不是。MFA 是控制項；Defense in Depth 才是涵蓋架構的根本原則。

Q089 雲端最常見的無意行為後果是什麼？

A 忘記關閉無用 VM，造成 resource sprawl。不是一定立刻變成 disaster。

Q090 Public cloud 資料中心控制治理通常由誰制定？

A Cloud provider。不要直接選 regulator。

Q091 Uptime Tier I 到 IV 分別是什麼？

A I Basic Capacity；II Redundant Capacity Components；III Concurrently Maintainable；IV Fault Tolerant。

Q092 Uptime Tier-defined facilities 的燃油基準？

A 12 hours at N load。

Q093 ASHRAE A1—A4 建議溫度範圍？

A 18—27°C。93°F 顯然過高。

Q094 資料中心 Physical / Environmental / Resilience 各涵蓋什麼？

A Physical：選址與實體進出；Environmental：HVAC、溫濕、氣流、消防；Resilience：UPS、發電機、燃油、冗餘電力 / 冷卻 / 連線。

Q095 NAS 與 SAN 差在哪？

A NAS 是檔案層網路儲存；SAN 是區塊層儲存網路。

Q096 VLAN 在考試中常被當成什麼控制？

A 網路分段 / 隔離手段。不要把它當成加密或身分驗證。

Q097 SDN control plane 的角色？

A 集中決定轉送策略；data plane 依此轉送流量。

Q098 Data dispersion 與 encryption 為何有協同效應？

A 先加密再切碎分散：攻擊者拿到的是不完整亂碼碎片，互補彼此單獨使用的弱點。

Q099 Asset inventory 加 personnel training 有 synergy 嗎？

A 通常沒有。兩者平行解決不同問題，不會互相放大同一攻擊路徑的防禦。

Q100 Cloud data center campus 入口常見什麼？不該把哪個當成敏感區控制？

A 應有 badging 等入口程序；mantrap 較屬敏感區 / 機房內層控制，不是所有 campus access point 的必備項。

Q101 VM configuration management 工具應包含什麼？

A Log file generation，以支援變更追蹤與事件調查。不要只選 anti-tampering。

Q102 哪種控制會影響 egress monitoring 的可視性？

A Encryption。加密後監控方案更難檢查內容。

Q103 Enhanced authentication 為什麼不該用 variable keystrokes？

A 每次擊鍵都不穩定就無法建立可靠生物特徵範本。Variable ≠ 有用的 dynamic factor。

Q104 Type 1 hypervisor 的關鍵特徵？

A 直接跑在硬體上 (bare metal)，不是裝在一般宿主 OS 裡的 Type 2。

Q105 Live migration 的維運用意？

A 把 workload 移到其他節點，使主機可進入 maintenance 而不中斷服務。

Q106 Management plane 為什麼要隔離？

A 它能控制整個雲環境；被攻破等於控制面失守，應與 production 資料面分離。

Q107 Hot aisle / cold aisle 目的？

A 組織氣流，讓空調有效帶走熱氣。亂放東西會破壞氣流設計。

Q108 Clustered host 進入維護前先做什麼？

A Drain / migrate workload，確保服務由其他節點承載。

Q109 OSI 題在 D3 常考什麼判斷？

A 先判斷題目在問哪一層的控制（例如網路分段、傳輸加密、應用識別），不要看到「網路」就一律選同一層。

Q110 第三方 / 供應鏈對基礎設施的意義？

A 你的 CSP 還可能依賴其他 subprocessors；評估時要看整條 dependency chain。

Q111 發現未授權 API 時，為什麼不該立刻封鎖？

A 可能中斷合法業務。ISC2 常要先 gather more data，釐清業務需求與影響。

Q112 雲端開發者最容易失去哪項控制權？

A 底層 logging，因為日誌設施通常由 CSP 掌握。不是欄位驗證。

Q113 開發人員測試自己程式的核心問題是什麼？

A Conflict of interest / vested interest：他們希望軟體表現良好，因而產生盲點。

Q114 Forklifting 是什麼？

A 傳統應用不經修改直接搬上雲端，即 lift and shift。

Q115 REST 與 SOAP 怎麼分？

A SOAP 依賴嚴格 XML 協定標準；REST 核心優勢是輕量與可擴展。不要說 REST 建立在同樣嚴格的協定標準上。

Q116 IAM 的終極目的是什麼？

A Accountability（可歸責）。Authorization 只是過程。

Q117 ISO 27034 的 ONF 與 ANF 數量關係？

A 組織只有 1 個 ONF；每個應用有 1 個專屬 ANF。

Q118 要找程式設計邏輯錯誤，弱點掃描夠嗎？

A 不夠。弱掃描已知系統弱點；邏輯錯誤靠原始碼審查 / SAST。

Q119 SAST 與 DAST 差在哪？

A SAST 看原始碼（白箱、開發期）；DAST 測運行中應用（黑箱、執行期）。

Q120 IAST 與 RASP 差在哪？

A IAST 在測試 / 執行中儀測以找漏洞；RASP 在執行期於應用內防禦攻擊。

Q121 API Gateway 與傳統防火牆差在哪？

A API Gateway 理解 API 呼叫、驗證、限流與應用層政策；傳統防火牆主要在網路層過濾。

Q122 Secure SDLC 的 shift left 是什麼意思？

A 把安全活動前移到需求、設計與開發，而不是只在上線前掃描。

Q123 Threat modeling 主要回答什麼？

A 系統有哪些資產、威脅、攻擊路徑與應優先的對策。

Q124 PaaS 測試的典型限制是什麼？

A 客戶可能無法對底層平台做完整基礎設施測試，只能在被允許的應用層範圍測試。

Q125 Code signing 的目的？

A 證明軟體來源與完整性，讓執行前能驗證發行者與未被篡改。

Q126 Nonfunctional requirements 常見包含什麼？

A 效能、可用性、可擴充性、安全性、可維護性等，不是功能清單本身。

Q127 Federated identity 解決什麼？

A 讓使用者用可信身分提供者的身分，跨組織 / 雲服務存取，而不在每個 SP 各建一套帳號。

Q128 OWASP Top 10 在 CCSP 怎麼用？

A 作為 Web / 應用常見風險清單與溝通框架，不是唯一合規標準。

Q129 Side-channel attack 在雲端為何被討論？

A 共享硬體可能讓攻擊者從時序、快取、電源等旁路推斷資訊。

Q130 應用安全題看到 best / first 時先問什麼？

A 這是治理 / 調查優先，還是立刻做技術強制。ISC2 常先選釐清與最小業務衝擊。

Q131 為什麼「工程師不擅長測試」通常是錯的？

A 那是情緒性說法。考試要的是獨立測試與利益衝突，不是能力貶低。

Q132 Release acceptance 的主要目的是什麼？

A 確認發行物符合既定驗收準則後才放行。文件化與核准是支撐，不是最上位目的。

Q133 日誌跨系統關聯的第一先決條件是什麼？

A Clock synchronization / NTP。不是 RAM 或磁碟容量。

Q134 Honeypot 的合法用途有哪些？

A 偵測、分流注意力、拖延、蒐集威脅情報。

Q135 Honeypot 不能做什麼？

A 主動招攬攻擊者 (luring)。那可能構成 entrapment，傷害後續追訴。

Q136 雲端自動修補最大死角是什麼？

A Snapshot / saved / dormant VM images 收不到 patch，被喚醒後帶已知漏洞上線。

Q137 Baseline 發揮完整價值的必要條件？

A Documentation。沒寫下來就無法定義、證明與還原偏離。

Q138 Baseline 是防毒或 HIDS 嗎？

A 不是。它是用來比較的安全組態標準。

Q139 發現 baseline deviation 應該直接改回去嗎？

A 不要。應 document → assess → authorize 或 remediate → 若屬合法變更則更新 baseline。

Q140 Configuration maintenance 包含什麼？不包含什麼？

A 包含 baseline、變更、patch、版本控制、驗證、偏離管理、文件。不包含 social engineering。

Q141 Production patch 為什麼不能看到更新就部署？

A 要評估 compatibility、可用性衝擊與變更風險：Identify → Evaluate → Test → Approve → Deploy → Validate。

Q142 Vendor guidance 能否取代 risk owner？

A 不能。Vendor 建議重要，但風險所有者仍是你的組織。

Q143 Host 進入 maintenance 前，cluster 通常先做什麼？

A Move / drain workload，或確保其他節點仍能承載服務。

Q144 Maintenance mode 可以停 monitoring / logging 嗎？

A 不行。維護期間仍要保留監控與日誌，才能驗證與調查。

Q145 維運生命週期口訣？

A Baseline → Harden → Document → Monitor → Detect deviation → Change management → Patch / test → Remediate → Re-baseline。

Q146 Exposure Factor 受什麼影響最大？

A Type of threat vector。它決定破壞機制與可能損失百分比。

Q147 SLE 與 ALE 公式？

A $SLE = AV \times EF$ ； $ALE = SLE \times ARO$ 。

Q148 Risk treatment 四種？

A Avoid、mitigate、transfer / share、accept。殘餘風險最終必須被適當接受。

Q149 ITIL 是什麼？

A IT service management 框架。不要當成資安控制目錄或法律。

Q150 COBIT 偏向什麼？

A IT 治理與控制目標，不是單純技術組態基準。

Q151 Golden image 為何是修補風險？

A 映像檔若過期，之後大量克隆會複製未修補狀態。

Q152 跨時區 VM patching 要注意什麼？

A 維護窗必須對應各系統本地風險與業務時間，不能只用單一總部時區硬切。

Q153 Hardening 與 auditing 差在哪？

A Hardening 是減少攻擊面的強化；auditing 是驗證與舉證。不要把稽核當強化本身。

Q154 Management plane isolation 的維運意義？

A 管理面被攻破可控制所有 guest；應獨立網路、強認證與嚴格存取。

Q155 HA、clustering、live migration 怎麼分？

A HA 是整體可用性目標；clustering 提供節點互相承接；live migration 是把運行中 workload 挪走以便維護。

Q156 為什麼離線就等於可能未修補？

A 自動化修補通常只打到 running instance。

Q157 Configuration drift 沒有文件時為何無法證明？

A 沒有基準就無法證明「現在」偏離「應有狀態」。

Q158 定量風險裡 AV、EF、ARO 各是什麼？

A AV 資產價值；EF 單次事件損失比例；ARO 年發生率。

Q159 殘餘風險最後要誰處理？

A 必須被適當的管理層接受，或繼續處理到可接受。不能懸空。

Q160 SIEM 的價值建立在什麼前提？

A 可靠、同步、集中的日誌。沒有時間同步就很難做事件重建。

Q161 Patch 責任在共享責任模型裡怎麼想？

A 誰能改那一層誰就有操作責任：guest OS / app 常是客戶；底層 hypervisor / host 常是 CSP。

Q162 Honeypot EXCEPT 題秒選什麼？

A Luring attackers。

Q163 問 baseline 必要條件時不要選什麼？

A 不要選培訓或 HIDS；選 documentation。

Q164 維護完成後還缺哪一步？

A Validate 後 return to service，必要時更新 baseline。

Q165 CMM 用來評估什麼？

A 流程機制的嚴謹度、細節與可重複性 (repeatability)。看到這些詞不要選 CSA STAR。

Q166 CSA STAR 用來做什麼？

A 檢驗 / 展示雲端安全控制保證，不是量測流程成熟度。

Q167 收到訴訟通知應立刻做什麼？

A 啟動 Legal Hold，暫停常規 secure destruction / retention 銷毀，以保全證據。

Q168 Legal hold 時要暫停威脅建模嗎？

A 通常不是優先動作。優先是保全可能相關的資料與日誌。

Q169 出庭前負責監管證物完整性的人是誰？

A Evidence Custodian。不要選 Data Controller。

Q170 Chain of custody 證明什麼？

A 證物從收集到呈堂過程中的保管、移轉與完整性未被破壞。

Q171 SOC 2 與 SOC 3 差在哪？

A SOC 2 詳細且通常 restricted use；SOC 3 較高階、較常可公開。

Q172 看到「公開摘要」與「詳細控制」分別偏向哪份 SOC？

A 公開摘要偏 SOC 3；詳細控制與受限分發偏 SOC 2。

Q173 ISO / IEC 是法律嗎？

A 不是。它是制定國際標準的組織 / 標準體系。

Q174 FedRAMP 是什麼？

A 美國聯邦雲端安全授權計畫，針對雲端服務給政府使用的授權路徑。

Q175 NIST SP 800-53 是什麼？

A 安全與隱私控制目錄，不是稽核報告，也不是成熟度模型。

Q176 HIPAA 主要保護什麼？

A 美國健康資訊（PHI）的隱私與安全要求。不要和 GLBA（金融）或 PCI（支付卡）搞混。

Q177 Common Criteria 是什麼？

A IT 產品安全評估與保證等級框架（EAL 等），不是雲端營運稽核報告。

Q178 Auditability 強調什麼？

A 活動可被記錄、追蹤與獨立驗證。沒有 log / clock sync / custody 就很難審計。

Q179 eDiscovery 與一般 backup 差在哪？

A eDiscovery 是為訴訟 / 調查識別、保存、產出電子證據；backup 是復原營運資料。

Q180 EU privacy adequacy 大致在問什麼？

A 第三方國家是否被認定提供足夠個資保護，以支持跨境傳輸。

Q181 GLBA 與 PCI DSS 再次對照？

A GLBA = 美國聯邦金融隱私法；PCI DSS = 支付卡安全標準。

Q182 DMCA / copyright 題不要選成什麼？

A 不要選成隱私或資安控制框架。它處理著作權與數位內容保護。

Q183 ISO 31000 與 NIST 800-37 各偏什麼？

A ISO 31000 是風險管理原則；NIST 800-37 是 RMF（風險管理框架）流程。

Q184 Right to Audit 通常出現在哪？

A 合約 / SLA 條款，讓客戶或指定稽核人有權查核 CSP 控制。不是單靠公開行銷聲明。

Q185 Privacy Level Agreement 常被考的是什麼？

A 隱私相關義務，尤其通報 / reporting obligation，而不只是時間長短。

Q186 合約 / SLA incentive 的作用？

A 用獎懲驅動 CSP 達成可用性、安全或通報義務，而不只寫願望。

Q187 資料跨境時最該先想到什麼？

A Jurisdiction、當地法律與能否合法轉移 / 存取資料。

Q188 Forensic reporting 最在意什麼？

A 方法可辯護、證據完整、chain of custody 清楚。不是先追求最快修復。

Q189 Evidence integrity 常見技術控制？

A Hashing、寫保護、雙人保管、完整日誌。分類本身不能替代保管鏈。

Q190 把工作交給 processor 後，controller 還要做什麼？

A 選擇適當 processor、用合約約束、持續監督。歸責不因委外而消失。

Q191 SOC 報告能不能當成「我已完全合規」？

A 不能自動等同。要看 Type、期間、範圍與是否涵蓋你關心的控制。

Q192 訴訟保全時 retention 政策怎麼辦？

A 與本案可能相關的資料停止例行銷毀，即使原本到期。

Q193 用一句話說明 TLS 四段工作？

A Certificate 綁定身分與 public key；digital signature 證明持有 private key；(EC)DHE 建立 shared secret；symmetric crypto 保護實際流量。

Q194 Symmetric encryption 的核心？

A 同一把 secret key 做加解密。適合大量資料，所以 bulk / TLS application traffic 用它。

Q195 Symmetric 最大問題是什麼？

A Key distribution：雙方如何安全取得同一把 secret。

Q196 Asymmetric cryptography 使用什麼？

A Public key + private key 這一對 mathematically related keys。

Q197 要給 Bob 機密訊息時用哪把 key 加密？

A Bob 的 public key 加密，Bob 的 private key 解密。目的是 confidentiality。

Q198 數位簽章用哪把 key？

A 簽署者 private key 簽名，對應 public key 驗證。

Q199 Digital signature 提供什麼、不提供什麼？

A 提供 integrity、authenticity、non-repudiation support；不提供 confidentiality。

Q200 為什麼不要說「用 private key 加密」來形容簽章？

A 這是舊簡化。CCSP 較安全的說法是 sign with private key、verify with public key。

Q201 Hash 單獨能證明是誰產生的嗎？

A 不能。任何人改完內容都可以重算 hash。Hash 只能協助偵測修改。

Q202 HMAC 為什麼通常不能給真正 non-repudiation？

A 雙方共享同一 secret，理論上都能做出 valid MAC。

Q203 X.509 certificate 最重要的一句？

A 把 identity / subject 與 public key 綁在一起，並由 CA 數位簽章證明此 binding。

Q204 Certificate 裡有 private key 嗎？

A 不應有。公開憑證帶 public key；private key 必須另外保密。

Q205 CA 的主要工作是什麼？

A 依程序驗證 subject，並用 CA private key 簽署憑證。不是幫你加密流量。

Q206 誰驗證 CA 在憑證上的簽章？

A Client 用 CA public key 驗證。

Q207 PKI chain of trust 怎麼走？

A Root CA → Intermediate CA → server certificate。Trust store 預先信任 root。

Q208 憑證驗證至少要看哪些？

A 簽章 / 鏈、有效期、主體 / hostname (SAN)、key usage、撤銷 (CRL / OCSP)。

Q209 憑證過期後 public key 數學上會壞掉嗎？

A 不會。但 PKI 驗證應拒絕，因為超出核准有效期。這是 trust validity 不是數學失效。

Q210 只偷到 server 的公開憑證能冒充伺服器嗎？

A 不能。關鍵秘密是 private key。

Q211 TLS 是 hybrid cryptosystem 的原因？

A 非對稱 / DH 做認證與金鑰建立；對稱金鑰做大量加密。全非對稱太慢，全對稱無法安全起步。

Q212 TLS 1.3 中 certificate 與 ECDHE 各做什麼？

A Certificate / signature = authentication；ECDHE = key establishment。兩者是不同功能。

Q213 TLS application traffic 用什麼加密？

A Derived symmetric traffic keys，常見 AES-GCM 或 ChaCha20-Poly1305 (AEAD)。

Q214 ECDHE 最大安全特性？

A Forward secrecy：每個 session 用 ephemeral keys，長期金鑰失竊不應讓過去流量自動可解。

Q215 ECDSA 與 ECDHE 差在哪？

A ECDSA = digital signature；ECDHE = key establishment。不要混。

Q216 TLS 1.3 還用傳統 RSA static key exchange 嗎？

A 不用。那是舊 TLS 常見、且無 forward secrecy 的做法。

Q217 為什麼「X.509 產生 shared secret」不精確？

A 憑證主要做身分綁定與認證；TLS 1.3 的 shared secret 通常由 (EC)DHE 建立。

Q218 AES-GCM 為什麼常出現在 TLS？

A 它是 AEAD，可同時提供機密性與密文完整性。

Q219 TLS 1.3 cipher suite 名稱還會寫出 ECDHE / RSA 嗎？

A 通常不會。TLS 1.3 把憑證演算法與 ECDHE group 分開協商，例如 TLS_AES_128_GCM_SHA256。

Q220 mTLS 是什麼？

A 雙方都出示憑證：server authentication + client certificate authentication。一般公開 HTTPS 未必做 client cert。

Q221 CRL 與 OCSP 差在哪？

A CRL 下載撤銷清單；OCSP 詢問特定憑證的撤銷狀態。

Q222 Root CA 為什麼能被信任？

A 它是 trust anchor，已預先放在 OS / browser trust store。不是因為 self-signed 就自動可信。

Q223 Self-signed certificate 的信任問題？

A Subject = Issuer，密碼學上可驗簽，但缺少外部可信 CA 時必須另有 out-of-band trust。

Q224 Certificate、KMS、HSM 差在哪？

A Certificate = 身分與 public key 綁定；KMS = 金鑰生命週期管理；HSM = 受保護硬體做金鑰運算。

Q225 大量資料加密看到題目先選什麼？

A Symmetric。

Q226 問「誰簽的、完整性 + 不可否認」選什麼？

A Digital signature。

Q227 問「完整性 + 共享密鑰認證」選什麼？

A HMAC。

Q228 問 TLS fresh shared secret 選什麼？

A (EC)DHE。

Q229 問 forward secrecy 選什麼？

A Ephemeral Diffie–Hellman / ECDHE。

Q230 最不能外洩的是什麼？

A Private key。

Q231 Authentication 與 confidentiality 各回答什麼？

A Authentication：你是誰？Confidentiality：未授權者能否讀懂？

Q232 瀏覽器收到 server X.509 的主要密碼學目的？

A 透過可信 CA 簽章，把伺服器身分綁定到 public key。